

POgrid.id

Refactor & Security Remediation Plan

Engineering Remediation Roadmap · v1.0

Prepared: 12 August 2026 · Classification: Internal — Engineering

Laravel 11 · Inertia.js v2 · React 18 · TypeScript · Tailwind v4 · Vite 8

This document translates the codebase audit (POgrid-Audit-2026-08-12.pdf) into a prioritized, test-gated remediation plan. All 7 critical and 14 high findings from the audit are mapped to surgical, bounded tasks across four execution phases. Domain logic the audit explicitly rates as strong (observer-driven progress engine, additive-delta model, QC-rework sub-stages, sunk-cost protection) is intentionally left untouched.

Deliverable status: All critical findings verified against the current working tree on the date of preparation. Line references were reconfirmed for the security cluster (C1–C5) and the two frontend render crashes (C6, C7).

Contents

#	Section	Phase	Findings	
1	Executive Verdict & Scope	1	Immediate	N/A
2	Phase 1 — Stop the Bleeding	1	Immediate	C1–C7, M2, M3, §6.1
3	Phase 2 — High Severity	2	Weeks 2–4	H1–H4, M1, M4–M6, §4.x, §6.4
4	Phase 3 — Structural	3	Quarter	God-objects, typing, i18n, CI
5	Testing & Verification Strategy	All	Ongoing	N/A
6	Risk Register & Tradeoffs	All	Ongoing	N/A
7	Open Questions	All	Resolve early	N/A

Finding severity reference: 7 Critical · 14 High · 21 Medium · 18 Low / Info — per the commissioning audit. This plan addresses 100% of critical and high findings.

1. Executive Verdict & Scope

POgrid.id's domain core is genuinely strong. The observer-driven progress cascades, additive-delta progress model, QC-rework sub-stage spawning, and sunk-cost protection are thoughtful, well-tested designs (~6,700 LOC of feature tests across 14 suites). Tenant isolation on worker-mutating endpoints is verified solid, there is no `$request->all()` mass-assignment anywhere, no XSS sinks, and zero TODO/FIXME/HACK comments in application code.

The production risk concentrates in two clusters and one systemic gap:

(A) Authorization collapse. The *verified* middleware is a no-op: *User* does not implement *MustVerifyEmail*, so the *instanceof* check on the middleware never matches and every office route is reachable by any authenticated floor worker. Combined with a permissive *UserPolicy::manage* and an unguarded PIN-reset approval, full tenant-admin account takeover is feasible from a 4-digit PIN session. A cross-tenant write IDOR in the PPIC endpoints and a logo-upload RCE close out the critical set.

(B) Frontend delivery discipline. 561 TypeScript compile errors never surface because *npm run build* is a plain *vite build* (esbuild strips types without checking). Two render-time *ReferenceErrors* white-screen the most-used pages (Worker floor dashboard; Owner Dashboard matrix tab).

Verdict: All critical findings are fixable with small, high-certainty diffs. This plan prioritizes closing the security cluster first, wire the type-check gate, then address high severity and structural debt.

2. Phase 1 — Stop the Bleeding (Week 1)

All tasks below are bounded and test-gated. Phase 1 exit gate: 7 critical findings closed, *RoleSecurityRemediationTest* extended, *npm run typecheck* green, full *php artisan test* green. No domain-logic changes.

Task	Finding	Action (surgical)	Effort
T1 — Office route gate	C1, M3	New <i>office</i> middleware (<code>role_level == office</code>) on the <code>routes/web.php:59</code> group; remove the testing-env bypass in <i>EnsureEmailsVerified</i> ; do NOT make <i>User</i> implement <i>MustVerifyEmail</i> .	~1h
T2 — UserPolicy tighten	C2	Allow <i>manage()</i> only for office roles; forbid non-owners granting office roles; block self role-change at <i>updateUser</i> .	~2h
T3 — PIN-reset hardening	C3, HIGH-untested	Authorize <i>approvePinReset</i> ; never persist plaintext PIN (flash-only + one-time reference); throttle request endpoint; fix <code>item_id=0</code> FK bug.	~2h
T4 — PPIC IDOR	C4	<code>view-tenant</code> + office/PPIC gate on <i>updatePo</i> & <i>updateItemPriority</i> ; stop re-pinning tenant scope to a foreign slug.	~30m
T5 — Logo RCE	C5	<i>storePublicly()</i> with hash+MIME name from <code>storage/</code> ; <code>.htaccess</code> engine-off in <code>public/uploads</code> ; office-only gate.	~1h
T6 — Render crashes + typecheck	C6, C7	Fix <code>Worker/Dashboard.tsx:1858</code> + <i>ActiveDelayDirectory</i> missing props; add <code>tsc --noEmit</code> to build + CI (zero NEW errors first).	~3h
T7 — Missing happy-path tests	§6.1	PIN-reset happy path, forgot/reset password, profile, <i>BackfillItemStages</i> guards.	~3h

2.1 Key remediation detail — C1 root cause

`routes/web.php:59` applies '*verified*' to the office group. The middleware *EnsureEmailsVerified.php:22* only blocks when *user instanceof MustVerifyEmail*. `app/Models/User.php:11` extends *Authenticatable* (no verification interface), so the guard is false for every user and the middleware is a silent no-op — confirmed in the working tree on 2026-08-12. The fix is a dedicated *office* role gate, not re-activating the half-dead email-verification flow.

2.2 Key remediation detail — C3 credential recovery

PIN reset is the only credential-recovery path for floor workers, has zero happy-path tests, and currently persists the new plaintext PIN into a broadcast alert. Remediation keeps UX (admin approves, worker sees PIN once) while removing plaintext-at-rest and enforcing an admin/owner gate.

3. Phase 2 — High Severity (Weeks 2–4)

ID	Finding	Action	Effort
H2	Office login unthrottled	throttle:5,1 on POST /login with per-username key	0.5h
H3	Weak PIN policy	6-digit min; per-user_id throttle key; lockout/backoff after N failures	2h
H1	Telemetry leak across tenants	Add items.tenant_id filter to both raw DB queries (WorkerDashboardController)	0.5h
H4	Credentials in logs/flash	Gate mail logger to local env; strip temp password from flash; redact tokens	1h
M1	TenantScope fails open	Fail closed (whereRaw('1=0') or throw) when no tenant set + not bypassed	1h
M4	SESSION_SECURE_COOKIE unset	Set true in prod .env; consider HSTS	10m
M5	Password policy divergence	Centralize Password::min(8)->numbers() rule	0.5h
M6	CSV/XLSX formula injection	Prefix =,+,@,- cells with a single quote in ExportService	0.5h
§4.3	Draft restore fragility	Schema/version guard on CreatePo draft; scope DRAFT_KEY per tenant	2h
§4.7	Systemic duplication	Extract shared permissions/Echo-Pusher/clock modules	3h
§4.4	Missing onError handlers	Add to worker progress/kendala/rework/finance mutations	1h
§6.4	Deploy fragility	Single deploy script; add migrate --force; decide --delete; drop public/hot artifact	2h

Defer decision: Laravel 12 upgrade (framework EOL March 2026) and PHPUnit upgrade are scheduled as a dedicated migration task, not bolted onto this work.

4. Phase 3 — Structural (Quarter)

- Decompose Owner/Dashboard.tsx (4,203 LOC) and WorkerDashboardController.php (1,946 LOC); extract getTelemetryData (~500 LOC) and validateStageAccess (~140 LOC) into services.
- Adopt types/index.d.ts shared models (imported by zero files today; three divergent local Item interfaces exist). Type useTranslation keyed by locale JSON; ratchet strict: true.
- Code-split pages via React.lazy per page group; stop eager-bundling the 4,200-line Owner Dashboard with Pusher + Echo + all locales.
- Consolidate the three parallel i18n mechanisms into locale JSONs; stake inline-string parity for the EN/ID pair.
- Migrate inline style={{} blocks (~1,200) to theme-aware classes — the theme/cascade architecture is correct; this is adoption, not redesign.
- Add a PgSQL CI test job, an E2E smoke suite in CI, and a composer audit gate (policy.advisories.block: true).

5. Testing & Verification Strategy

- TDD per task: failing test → minimal implementation → green (enforced in Phase 1).
- Regression base: full php artisan test before and after every phase; composer test for the fast loop.
- Frontend: npm run typecheck wired into build + CI (Phase 1); existing Puppeteer/Jest E2E added to CI.
- Never regress: observers' weighted-progress cascade, QC-rework sub-stage spawn, sunk-cost TERMINATED logic, tenant isolation on worker mutations.

Exit criteria: 0 critical findings open; RoleSecurityRemediationTest covers a floor-role actor for every office endpoint; typecheck green; PgSQL parity job green.

6. Risk Register & Tradeoffs

Risk	Severity	Mitigation
Office middleware breaks legit hybrid flows	Med	Enumerate every route in the group during T1; set gates by declared intent.
Removing plaintext PIN changes admin UX	Low	PIN still delivered via flash on approve; one-time-token as follow-on option.
tsc --noEmit red-builds until 561 errors resolve	Med	Gate on zero NEW errors first, then ratchet to zero; do not ship a red build.
Deploy --delete risk to prod-only files	Med	Scope exclusions (storage/uploads) before enabling; unify script first.

7. Open Questions

Q. **Email verification:** keep 'verified' as a real future gate or delete it? Recommended: delete middleware, keep office gate.

Q. **PIN delivery:** is flash-only sufficient, or build one-time-token redemption? Recommended: flash-only for v1.

Q. **Logs/telemetry scope:** owner+office only, or visible to some floor roles?